MITRE ATLAS | AML.CS0022 - ChatGPT Package Hallucination

Entry Information

ID:
AML.CS0022

Type:
Case-Study

Name:
ChatGPT Package Hallucination

URL:
https://atlas.mitre.org/studies/AML.CS0022/

Incident Date:
2024-06-01

Target:
ChatGPT users

Actor:
Vulcan Cyber, Lasso Security

Description

Researchers identified that large language models such as ChatGPT can hallucinate fake software package names that are not published to a package repository. An attacker could publish a malicious package under the hallucinated name to a package repository. Then users of the same or similar large language models may encounter the same hallucination and ultimately download and execute the malicious package leading to a variety of potential harms.

Attack Procedure:
[AML.T0040] AI Model Inference API Access: The researchers use the public ChatGPT API throughout this exercise.
[AML.T0062] Discover LLM Hallucinations: The researchers prompt ChatGPT to suggest software packages and identify suggestions that are hallucinations which don't exist in a public package repository.

For example, when asking the model "how to upload a model to huggingface?" the response included guidance to install the `huggingface-cli` package with instructions to install it by `pip install huggingface-cli`. This package was a hallucination and does not exist on PyPI. The actual HuggingFace CLI tool is part of the `huggingface_hub` package.
[AML.T0060] Publish Hallucinated Entities: An adversary could upload a malicious package under the hallucinated name to PyPI or other package registries.

In practice, the researchers uploaded an empty package to PyPI to track downloads.
[AML.T0010.001] AI Software: A user of ChatGPT or other LLM may ask similar questions which lead to the same hallucinated package name and cause them to download the malicious package.

The researchers showed that multiple LLMs can produce the same hallucinations. They tracked over 30,000 downloads of the `huggingface-cli` package.
[AML.T0011.001] Malicious Package: The user would ultimately load the malicious package, allowing for

arbitrary code execution.
[AML.T0048.003] User Harm: This could lead to a variety of harms to the end user or organization.

References

- Vulcan18's "Can you trust ChatGPT's package recommendations?" — https://vulcan.io/blog/ai-hallucinations-package-risk

- Lasso Security Research: Diving into AI Package Hallucinations — https://www.lasso.security/blog/ai-package-hallucinations

- AIID Incident 731: Hallucinated Software Packages with Potential Malware Downloaded Thousands of Times by Developers — https://incidentdatabase.ai/cite/731/

- Slopsquatting: When AI Agents Hallucinate Malicious Packages — https://www.trendmicro.com/vinfo/us/security/news/cybercrime-and-digital-threats/slopsquatting-when-ai-agents-hallucinate-malicious-packages